

Nile Egypt Labs — website audit brief

Unauthenticated review of public pages on 16 Aug 2026, as a briefing for a deeper authorized audit. Primary URL nileegyptlabs.com/index.html. No login attempts, payload injection, or path guessing.

 **Highest-priority fact**
The public lab site is HTTP-only (TLS handshake fails). It advertises online results and links patients to a separate Azure-hosted results portal that does use HTTPS. Treat the results app as in-scope PHI, not as a brochure follow-on.

1
Critical

4
High

3
Medium

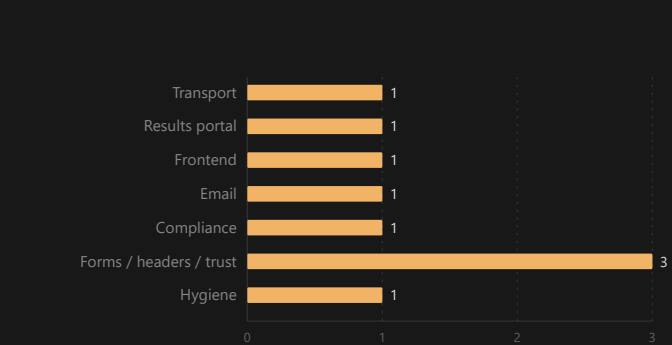
1
Low

Findings by severity



● Critical 1 ● High 4 ● Medium 3 ● Low 1

Where issues sit



Count of findings in this brief, grouped by area

Source: public HTTP/TLS/DNS/HTML review · 16 Aug 2026 · 9 findings

Two hosts, not one site

Host	Role	Stack	TLS	Last modified
 www.nileegyptlabs.com	Marketing brochure	IIS 10 + ASP.NET + PleskWin · 92.204.70.19 · Host Europe (Strasbourg)	HTTP only · HTTPS connection reset	21 Feb 2018 (home) · 29 Jun 2018 (contact)
 www.nileegyptlabresults.com	Patient / lab-to-lab results login	IIS 10 + ASP.NET 4.0.30319 + Angular SPA · 20.46.40.255 · Azure (Dubai)	HTTPS (Let's Encrypt) · HTTP 301 to HTTPS	7 Nov 2021 (login shell)

DNS: nileegyptlabs.com → GoDaddy ns43/ns44.domaincontrol.com. Mail: Microsoft 365. Results mail: hostedemail.com.

Findings

- All
- Critical
- High
- Medium
- Low

ID

F01

Severity

Critical

Area

Transport

Finding

Marketing site has no working HTTPS

Evidence

http://www.nileegyptlabs.com/index.html returns 200. TLS to https://www.nileegyptlabs.com and the apex host resets the connection. All pages, fonts, and scripts load over HTTP.

For the next audit

Issue a certificate, bind 443 on IIS/Plesk, redirect HTTP to HTTPS, then enable HSTS.

ID

F02

Severity

High

Area

Results portal

Finding

Lab-results app is the real PHI surface and is under-hardened

Evidence

Nav Online Result → Out Pation / Lab To Lab both point to http://www.nileegyptlabresults.com/, which 301/302s to https://www.nileegyptlabresults.com/Login/. Login is an Angular SPA (Last-Modified 7 Nov 2021) on IIS + ASP.NET 4.0.30319 at 20.46.40.255 (Azure, Dubai). HTTPS works (Let's Encrypt, valid 30 Jul 2026–28 Oct 2026). Login response has no HSTS, CSP, X-Frame-Options, or X-Content-Type-Options. Server and ASP.NET version are disclosed.

For the next audit

Authorized test of auth, session cookies, IDOR on result records, API authz, logout, and MFA. Add HSTS and security headers before that test.

ID

● F03

Severity

High

Area

Frontend

Finding

End-of-life JavaScript libraries on every public page

Evidence

js/jquery.js is jQuery 1.10.2 (file date 6 Nov 2014). js/bootstrap.min.js is Bootstrap 3.3.4 (16 Mar 2015). Both have long-published XSS issues in the public CVE record.

For the next audit

Replace with current jQuery 3.x or drop jQuery; move to a maintained CSS/JS stack. Do not leave 2013–2015 libraries on a healthcare origin.

ID

● F04

Severity

High

Area

Email

Finding

SPF hard-fail does not match Microsoft 365 mail; no DMARC

Evidence

MX is nileegyptlabs-com.mail.protection.outlook.com. SPF is v=spf1 include:secureserver.net -all. TXT also publishes NETORGFT11185445.onmicrosoft.com. _dmarc.nileegyptlabs.com does not exist. Results domain SPF is hostedemail.com ~all, also no DMARC.

For the next audit

SPF must include spf.protection.outlook.com (or equivalent) before -all. Add DMARC p=quarantine then p=reject. Align DKIM on the M365 tenant.

ID

● F05

Severity

High

Area

Compliance

Finding

No privacy, cookie, or patient-data notice on a medical lab site

Evidence

Public pages have no privacy policy, cookie banner, terms, or data-controller identity. Forms ask for name, email, date of birth, and phone. Hosting is Host Europe / GoDaddy Plesk in Strasbourg (92.204.70.19) while patients are in Egypt.

For the next audit

Publish a PDPL-aligned privacy notice, lawful basis, retention, and cross-border disclosure. Confirm whether EU hosting of Egyptian health-adjacent data is intended.

ID

● F06

Severity

Medium

Area

Forms

Finding

Appointment and contact forms collect PII but do not submit

Evidence

Homepage appointment modal and contact.html forms have no action, method, or name attributes. Email field uses invalid type="mail". Classes are WordPress Contact Form 7 (wpcf7-*) on a static IIS site. Department options are Dental, cardiology, drugstore — leftover hospital template, not lab tests. custom.js has no form handler.

For the next audit

Remove dead forms or replace with a real backend over HTTPS, CSRF protection, and server-side validation. Do not collect date of birth until that exists.

ID

● F07

Severity

Medium

Area

Headers

Finding

Security headers absent on both hosts

Evidence

Marketing 200 responses send Content-Type: text/html (no charset), Server, X-Powered-By: ASP.NET, X-Powered-By-Plesk: PleskWin. No CSP, HSTS, X-Frame-Options / frame-ancestors, X-Content-Type-Options, Referrer-Policy, or Permissions-Policy. Results login is the same minus Plesk, plus X-AspNet-Version: 4.0.30319. Login does set Cache-Control: no-cache, no-store.

For the next audit

IIS/web.config header set on both sites. Strip X-Powered-By and X-AspNet-Version. Keep no-store on the login page.

ID

● F08

Severity

Medium

Area

Trust

Finding

Unfinished WpFreeware Medinova template still in production

Evidence

Homepage Last-Modified 21 Feb 2018. Footer still has Lorem Ipsum. Commented template mail info@wpfmedinova.com. Dummy blog copy (Dr. Smith / Dental). About page credits Template Design By WpFreeware Team. Social links include Google+. Map iframe uses a Google Maps browse URL, not an embed. Developer name Eng:-Androw Nader is in the footer.

For the next audit

Ship a finished lab site or take the brochure offline. Leftover template copy is a phishing/impersonation risk for a lab that advertises online results.

ID

● F09

Severity

Low

Area

Hygiene

Finding

No robots.txt or sitemap; charset and copy quality

Evidence

robots.txt and sitemap.xml 404. Directory listing on /images/, /js/, /css/ returns 403 (good). Nav typo Out Patien. Service copy has many spelling errors. Google Fonts requested over HTTP.

For the next audit

Add robots/sitemap after HTTPS. Serve fonts over HTTPS. Keep directory listing disabled.

What already looks acceptable

Folder URLs `/images/`, `/js/`, and `/css/` return 403, so directory listing is off.

The results origin redirects HTTP to HTTPS and the login HTML sets `Cache-Control: no-cache, no-store`.

Corporate mail is on Microsoft 365, which is a solid platform once SPF and DMARC are corrected.

Recommended further audit

This pass only read public pages. The next engagement should be written authorization covering both hostnames, with the results SPA as the primary target.

Phase 1 — marketing origin

Confirm whether `nileegyptlabs.com` should stay live. If yes: TLS, redirect, HSTS, header pack, remove Plesk/ASP.NET banners, replace jQuery/Bootstrap, delete or rebuild forms, strip Medinova leftover copy.

Out of scope for a pentest until HTTPS exists: mixed-content retest, cookie flags, and CSP report-only.

Phase 2 — results origin (PHI)

Authorized review of `nileegyptlabresults.com`: authentication, session cookies (Secure / HttpOnly / SameSite), account lockout, MFA, authorization between outpatient and lab-to-lab roles, object-level access to result records, and the Angular API behind `/Login/`.

Do not test this from an unauthorized account. Login was not attempted in this brief.

- ☐ Get written scope: nileegyptlabs.com + nileegyptlabresults.com, including APIs after login
- ☐ Turn on HTTPS and HSTS on the marketing host; change Online Result links to https://
- ☐ Add security headers and hide Server / X-Powered-By / X-AspNet-Version on both IIS sites
- ☐ Fix SPF for Outlook, add DMARC, verify DKIM; treat email spoofing as a patient-trust issue
- ☐ Replace jQuery 1.10.2 and Bootstrap 3.3.4; dependency and SCA scan
- ☐ Authorized results-portal test: auth, session, IDOR, role split, export/download of lab reports
- ☐ Privacy / PDPL review: notices, retention, EU and UAE hosting of Egyptian lab data
- ☐ Rebuild or remove appointment/contact forms; never collect DOB on a static HTTP page

Method notes

Checks used: homepage, about, contact, features, linked JS/CSS, DNS (A/MX/TXT/NS/DMARC), TLS handshake, results login GET, and in-browser review of the Online Result menu. Directory listing was checked only on folders already referenced by the HTML. This is not a penetration test and does not prove absence of other issues.

Brief prepared for a follow-on audit · Nile Egypt Labs public web properties · 16 Aug 2026